SIMATS ENGINEERING
ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking **COURSE CODE: ITA1410**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Report Analysis
Questions

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**

2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.(**20 Mark).**

3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure..**(10 Marks)**

Code of Conduct:

I **T. Dharani Devi (192425036)** *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: **Dharani Devi T**

RUBRICS FOR CALCULATION

Report Analysis

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.
Identification of Security Risks and Vulnerabilities	25%	Correctly identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification.	Identifies most risks and vulnerabilities with minor errors.	Identifies only a few risks with limited technical explanation.	Fails to identify major risks or vulnerabilities.
Application of Cybersecurity Concepts and Countermeasures	30%	Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures.	Recommends suitable countermeasures with minor technical gaps.	Provides limited or partially appropriate recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Documentation	20%	Response is well-organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandable with minor documentation or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

Question 1: Security Risk Analysis of Open Ports Identified Using Nmap

1. Introduction

Network security is an important part of protecting computers, servers, applications, and sensitive organizational information from unauthorized access. Every organization uses computer networks to share information, provide services, store data, and communicate with employees and customers. If these networks are not properly secured, attackers may gain access to confidential information or disrupt normal business operations.

Nmap (Network Mapper) is a network scanning tool used by security professionals to identify active hosts, open ports, running services, and operating system details. It helps administrators understand which services are accessible on a target system and identify possible security weaknesses.

In this case, a security analyst scanned the target system with IP address 192.168.1.10. The scan identified three important open ports:

- Port 80 – HTTP
- Port 22 – SSH
- Port 3306 – MySQL

The report also provided the operating system and service versions. This information helps the security team understand the system's configuration and identify software that may require security updates.

An open port is not automatically a vulnerability. However, an unnecessary, outdated, or incorrectly configured service can create a security risk. Therefore, the analyst must examine each service, evaluate its risks, and recommend suitable security controls.

2. Aim

To analyze the Nmap scan report for the target system 192.168.1.10, identify security risks associated with HTTP, SSH, and MySQL services, explain possible attack methods, and recommend appropriate security measures to protect the system.

3. Objectives

1. To understand the purpose of Nmap in network security assessment.
2. To identify the services associated with the detected open ports.
3. To analyze the security risks associated with HTTP, SSH, and MySQL.
4. To understand how attackers may misuse vulnerable or misconfigured services.
5. To examine the importance of operating system and service-version information.
6. To recommend suitable preventive and corrective security measures.
7. To improve the overall security of the target system through secure configuration and continuous monitoring.

4. Overview of the Nmap scan report

Nmap helps security analysts discover which network services are reachable from a particular scanning location. The results depend on the scan options, firewall rules, network conditions, and permissions of the analyst.

The target address 192.168.1.10 belongs to a private IPv4 address range commonly used in local area networks.

The following table summarizes the reported services.

Port	Service	Main purpose	Major security concern
80/TCP	HTTP	Provides web pages and web applications	Unencrypted traffic and vulnerable web applications
22/TCP	SSH	Provides secure remote administration	Weak passwords, stolen keys, and outdated software
3306/TCP	MySQL	Provides database access	Unauthorized database access and data exposure

The analyst must determine whether these services are necessary, who can access them, and whether their software versions are supported and fully patched.

5. Security risks associated with HTTP (Port 80)

5.1 Purpose of HTTP

HTTP stands for Hypertext Transfer Protocol. It is commonly used to transfer web pages, images, files, and application data between a web server and a browser.

When a user visits a website, the browser sends an HTTP request to the web server, and the server returns a response. Port 80 is the standard TCP port associated with HTTP.

HTTP is widely used because it supports web applications and communication between clients and servers. However, ordinary HTTP does not encrypt the contents of communication.

5.2 Major security risks of HTTP

1. Unencrypted communication

HTTP does not provide encryption by itself. Information transmitted through an HTTP connection may be exposed to someone who can monitor the network traffic.

If a web application sends login credentials, session cookies, or personal information over unencrypted HTTP, that information may be intercepted.

2. Exposure of sensitive information

Web applications sometimes display or transmit personal details, account information, or business records. If these resources are not properly protected, confidential information may be disclosed to unauthorized users.

3. Vulnerable web applications

The web server may run an outdated content management system, web framework, or application component. Known vulnerabilities in these components can allow attackers to access restricted resources or interfere with application operations.

4. Improper access controls

If the application does not verify user permissions correctly, an ordinary user may be able to access information or functions intended for administrators.

5. Directory listing and information disclosure

Incorrect server configuration may reveal file names, backup files, application directories, software details, or other information that should not be publicly accessible.

6. Cross-site scripting (XSS)

If an application handles untrusted input incorrectly, an attacker may be able to inject harmful browser-executed scripts into a page. Depending on the vulnerability, this can affect users' sessions or expose information available to their browsers.

7. Denial-of-service attacks

A web server with insufficient protections may be overwhelmed by excessive requests, causing slow responses or preventing legitimate users from accessing the website.

5.3 How an attacker could misuse HTTP

An attacker who can reach a vulnerable web server may attempt to identify its publicly accessible pages, discover outdated components, or find misconfigured resources.

For example, if a website exposes an old application version, an attacker may compare that version against publicly documented security advisories. If a known vulnerability remains unpatched, the attacker may attempt to exploit it.

An attacker may also take advantage of unencrypted communication on an accessible network to observe information transmitted between the browser and server.

These risks depend on the actual application, network position, access controls, and configuration. The presence of port 80 alone does not prove that any vulnerability exists.

5.4 Security measures for HTTP

1. Enable HTTPS: Use TLS certificates to encrypt web traffic and redirect ordinary HTTP requests to HTTPS where appropriate.
2. Update web software: Install security updates for the operating system, web server, framework, and application components.
3. Use secure authentication: Apply strong authentication and multifactor authentication for privileged accounts.
4. Configure access controls: Restrict sensitive pages, administrative interfaces, and files to authorized users.
5. Disable unnecessary directory listings: Prevent the server from exposing file and directory information.
6. Validate user input: Apply appropriate input validation and output encoding to reduce application vulnerabilities.
7. Use a web application firewall: A WAF can help detect and block certain malicious web requests.
8. Implement secure session management: Use secure cookie settings, appropriate session expiration, and session renewal after authentication.

9. Monitor web logs: Review unusual requests, repeated failures, suspicious URLs, and unexpected traffic patterns.
10. Conduct regular security testing: Perform authorized vulnerability assessments and application security testing.

6. Security risks associated with SSH (Port 22)

6.1 Purpose of SSH

SSH stands for Secure Shell. It is a network protocol used to connect securely to remote computers and servers. System administrators use SSH to execute commands, transfer files, manage services, and perform maintenance tasks.

SSH normally encrypts the connection, helping protect information exchanged between the client and server. However, encryption alone cannot prevent unauthorized access when authentication is weak or the server is misconfigured.

6.2 Major security risks of SSH

1. Weak passwords

If accounts use short, predictable, or reused passwords, attackers may attempt password guessing or automated credential attacks.

2. Brute-force login attempts

An exposed SSH service may receive repeated login attempts from unauthorized sources. If weak passwords are permitted and suitable protections are absent, an account may be compromised.

3. Stolen SSH private keys

SSH can use cryptographic keys for authentication. If a private key is stolen, poorly protected, or shared improperly, an attacker may be able to authenticate as its owner.

4. Outdated SSH software

Older versions of SSH servers or related operating-system components may contain known vulnerabilities. Running unsupported software increases the possibility of exploitation.

5. Excessive user privileges

If a compromised account has administrator or root privileges, the attacker may gain control over important system functions, files, and services.

6. Unnecessary remote access

Allowing SSH access from the entire internet or from every internal network increases the number of systems and users that can attempt to connect.

7. Poor account management

Former employees, unused accounts, shared accounts, and old authorized keys may remain active after they are no longer required.

6.3 How an attacker could misuse SSH

An attacker who can reach port 22 may try to identify the SSH implementation and its version, then compare that information with known security advisories.

If password authentication is enabled, the attacker may attempt repeated logins using guessed or previously exposed credentials. If a legitimate user's private key has been compromised, the attacker may attempt to use that key to access the server.

If access is successful, the attacker's actual capabilities depend on the privileges of the compromised account. A normal account may expose certain files or commands, whereas a privileged account may allow wider system changes.

A successful SSH compromise can lead to unauthorized file access, theft of sensitive information, modification of system configurations, or disruption of services.

6.4 Security measures for SSH

1. Use strong authentication: Prefer well-managed SSH key authentication and multifactor authentication where supported.
2. Disable direct root login: Require administrators to use individual accounts with controlled privilege escalation.
3. Restrict source addresses: Permit SSH connections only from trusted administration networks, VPNs, or approved addresses.
4. Disable unused accounts: Remove or lock accounts that no longer require remote access.
5. Protect private keys: Use secure file permissions, passphrases, and appropriate key-management procedures.
6. Update SSH software: Install supported versions and security patches.
7. Limit authentication attempts: Apply reasonable connection and authentication limits.
8. Use least privilege: Grant each account only the permissions required for its duties.
9. Monitor authentication logs: Investigate repeated failed logins, unusual login times, and unexpected source addresses.
10. Review authorized keys: Regularly audit and remove obsolete or unauthorized SSH keys.

7. Security risks associated with MySQL (Port 3306)

7.1 Purpose of MySQL

MySQL is a relational database management system used to store, organize, retrieve, and manage structured information.

Organizations use MySQL for websites, customer-management systems, online services, inventory systems, and business applications. Port 3306 is the standard TCP port commonly used by MySQL.

Databases may contain customer details, employee records, transaction information, application credentials, and other confidential data. Therefore, database access must be carefully controlled.

7.2 Major security risks of MySQL

1. Unauthorized database access

If the database is reachable by untrusted users and authentication or access restrictions are weak, an attacker may attempt to access database services.

2. Weak database passwords

Predictable or reused passwords can increase the likelihood of unauthorized access to database accounts.

3. Excessive permissions

A database account with unnecessary administrative privileges may be able to read, change, or delete more information than its legitimate function requires.

4. SQL injection

A vulnerable application may combine untrusted user input with SQL statements unsafely. This can allow an attacker to manipulate database queries through the application.

5. Public database exposure

A MySQL server generally should not be directly accessible from the public internet unless there is a carefully justified requirement and strong security architecture.

6. Outdated database software

Older MySQL versions may contain known vulnerabilities or may no longer receive security updates.

7. Sensitive data exposure

Poorly protected database files, backups, logs, or connections may expose personal information, business records, or authentication data.

8. Data modification or deletion

If an attacker gains sufficient database privileges, they may modify records, delete information, or disrupt applications that depend on the database.

7.3 How an attacker could misuse MySQL

An attacker who can connect to port 3306 may attempt to identify the database version, assess whether the service is improperly exposed, or test whether weak credentials are accepted.

If database credentials are compromised, the attacker may access the records permitted by that account. Excessive privileges could increase the damage by allowing unauthorized modifications or administrative actions.

Alternatively, an attacker may target a web application that communicates with the database. If the application contains a SQL injection vulnerability, the attacker may manipulate queries without needing direct database login access.

For example, an online shopping application may store customer orders and account details in MySQL. If its application account has excessive permissions and a vulnerability is exploited, information beyond the user's legitimate access may be exposed.

7.4 Security measures for MySQL

1. Restrict network access: Allow connections only from authorized application servers and administrative systems.
2. Avoid direct public exposure: Place the database on a private network behind appropriate firewall rules.
3. Use strong credentials: Require unique, strong passwords and protect database authentication secrets.

4. Apply least privilege: Give application accounts only the permissions necessary to perform their tasks.
5. Prevent SQL injection: Use parameterized queries or prepared statements and validate input appropriately.
6. Patch regularly: Install supported MySQL updates and security fixes.
7. Encrypt connections: Configure TLS for database connections where required by the network threat model.
8. Encrypt sensitive data: Protect sensitive information at rest using appropriate encryption and key-management practices.
9. Maintain secure backups: Protect backup files, restrict access, and test restoration procedures.
10. Enable auditing and logging: Monitor failed logins, unusual queries, permission changes, and unexpected database access.
11. Remove unnecessary accounts: Delete unused accounts and review database privileges regularly.
12. Test recovery procedures: Ensure that clean backups can be restored if information is corrupted, deleted, or encrypted by an attacker.

8. Importance of operating system and service-version information

The scan report also identifies the operating system and service versions. This information helps security analysts understand the technology running on the target system.

8.1 Benefits to the security analyst

- It helps identify outdated or unsupported software.
- It supports comparison with vendor security advisories.
- It helps determine which patches or upgrades may be necessary.
- It assists in planning compatibility testing before updates.
- It helps administrators identify unnecessary services and components.

8.2 Risks of information disclosure

Attackers may use version information to narrow down the vulnerabilities they investigate. For example, a particular software release may have a publicly documented vulnerability that has not been fixed on the target system.

However, a reported version does not automatically mean the system is vulnerable. Vendors may backport security fixes, and scan results can sometimes be inaccurate. Analysts should verify the installed version, patch status, vendor advisories, and actual configuration before drawing conclusions.

8.3 Recommended actions

1. Maintain an inventory of operating systems and installed services.
2. Remove unsupported software and replace it with supported alternatives.
3. Apply security patches according to risk and organizational policy.
4. Verify service versions through authorized administrative checks.
5. Disable unnecessary services and software components.

6. Retest systems after patching to confirm that the identified weaknesses have been addressed.

9. Overall security analysis of the target system

The Nmap report shows that the target system provides web access, remote administration, and database services. Each service supports important business functions, but each also requires appropriate security controls.

The following table summarizes the overall risk assessment.

Service	Possible weakness	Potential impact	Priority action
HTTP	Unencrypted communication or vulnerable application	Data exposure or website compromise	Enforce HTTPS and patch applications
SSH	Weak authentication or excessive access	Unauthorized remote access	Restrict access and strengthen authentication
MySQL	Unrestricted database access	Data theft, modification, or deletion	Isolate the database and enforce least privilege
Operating system	Missing security updates	Exploitation of known vulnerabilities	Patch and maintain supported software

The actual severity of each risk depends on the service configuration, network exposure, sensitivity of the information, and the presence of known vulnerabilities.

10. Recommended network security architecture

The organization should implement a layered security architecture to protect the target system.

Internet / External Network

Firewall and Network Security Controls

Filter traffic and permit only authorized connections

Web Server

HTTP redirected to HTTPS

Administration Access

Restricted SSH / VPN

Private Database Network

MySQL accessible only to authorized systems

Monitoring, Logging and Backup Systems

Figure 1: Suggested layered security architecture for the target system.

Explanation of the architecture

1. The firewall controls incoming and outgoing network connections.
2. The web server provides authorized web services using encrypted HTTPS communication.
3. SSH access is limited to approved administrators and trusted management networks.
4. MySQL is isolated from direct public access and accepts connections only from approved systems.
5. Monitoring and logging help the security team identify unusual activities.
6. Secure backups allow the organization to recover important information following an incident.

This architecture follows the principle of defense in depth, which means using multiple security controls rather than relying on a single protective mechanism.

11. General preventive security measures

11.1 Firewall configuration

The organization should review firewall rules and allow only the ports required for business operations. Port 80 may be retained for redirection to HTTPS if needed, port 22 should be restricted to trusted administration sources, and port 3306 should normally be limited to authorized application or database-management systems.

11.2 Regular vulnerability assessment

Security professionals should periodically scan authorized systems to identify open ports, outdated software, and misconfigurations. Findings should be verified before being classified as vulnerabilities.

11.3 Patch management

The organization should maintain an update schedule for operating systems, web servers, SSH implementations, database software, and application dependencies. Critical security issues should receive priority based on risk.

11.4 Strong access control

Every employee and application should have only the permissions required to perform its tasks. Administrator accounts should be separated from ordinary user accounts.

11.5 Security monitoring

System logs, web access logs, SSH authentication logs, database logs, and firewall events should be reviewed for unusual activities. Alerts should be generated for suspicious login attempts, unexpected service changes, and abnormal traffic.

11.6 Data protection

Sensitive data should be protected using encryption, appropriate access restrictions, secure backups, and controlled retention policies.

11.7 Incident response

The organization should establish procedures for detecting, containing, investigating, and recovering from security incidents. These procedures should identify responsible personnel and communication channels.

12. Steps to be followed by the security analyst

The security analyst can follow the steps below to assess and improve the security of the target system.

1. Obtain written authorization to assess the target system.
2. Review the Nmap report and identify all reachable services.
3. Confirm whether HTTP, SSH, and MySQL are necessary for business operations.
4. Verify operating system and service versions against trusted vendor documentation.
5. Review firewall rules and service configurations.
6. Assess authentication methods, access permissions, and encryption settings.
7. Identify and prioritize confirmed vulnerabilities according to their severity and potential impact.

8. Apply appropriate security patches and configuration changes.
9. Repeat the authorized assessment to verify that the weaknesses have been corrected.
10. Document the findings, corrective actions, and recommendations for future monitoring.

13. Expected outcome

After the recommended security measures are implemented, the organization should achieve the following improvements:

- Reduced exposure of unnecessary network services.
- Improved protection of information transmitted through web applications.
- Stronger authentication for remote administration.
- Reduced risk of unauthorized database access.
- Better visibility into suspicious network and account activity.
- Improved resistance to known software vulnerabilities.
- More reliable backup and recovery capabilities.
- A stronger overall security posture.

These improvements reduce risk but do not guarantee complete protection. Continuous monitoring, testing, and maintenance remain necessary.

14. Conclusion

The Nmap scan of 192.168.1.10 identified three important services: HTTP on port 80, SSH on port 22, and MySQL on port 3306. Each service serves a useful purpose, but improper configuration, weak authentication, excessive privileges, or outdated software can create security vulnerabilities.

HTTP requires secure web communication and properly maintained applications. SSH requires strong authentication, restricted remote access, and careful privilege management. MySQL requires database isolation, secure credentials, least-privilege permissions, and protection against SQL injection through vulnerable applications.

The operating system and service-version details also help the security analyst identify software that may require verification or updating. However, the scan results must be investigated before any service is considered vulnerable.

Therefore, the organization should combine firewall restrictions, secure configuration, regular patching, access control, encryption, monitoring, and periodic authorized assessments. Implementing these measures will help protect confidential information, maintain service availability, and reduce the risk of unauthorized access.

Question 2: Phishing Awareness Assessment Using GoPhish

1. Introduction

Phishing is a type of social engineering attack in which attackers try to trick people into revealing confidential information, clicking malicious links, downloading harmful attachments, or performing unauthorized actions. Phishing attacks commonly use emails that appear to come from trusted organizations, banks, managers, colleagues, or service providers.

Employees are often targeted because they regularly use email to communicate, share documents, access company applications, and handle business information. An attacker may create a fake email that looks like an official message and encourage the employee to click a link or open an attachment.

GoPhish is an open-source phishing simulation framework used by authorized security teams to conduct phishing awareness campaigns. It helps organizations measure how employees respond to simulated phishing emails and identify areas where additional security training is required.

In this case, ABC Technologies Pvt. Ltd. conducted a phishing awareness campaign using GoPhish. The report identified the following results:

- 40% of employees clicked the phishing link.
- 20% of employees entered their login credentials.
- Several employees downloaded a malicious attachment.

These results indicate that some employees may have difficulty identifying suspicious emails. The organization should use the findings to improve employee awareness, strengthen email security, and establish effective policies to reduce the risk of successful social engineering attacks.

2. Aim

To analyze the phishing awareness campaign conducted using GoPhish, identify employee-related security weaknesses, examine the risks associated with phishing attacks, and recommend suitable awareness programs, email security controls, and organizational policies.

3. Objectives

1. To understand the concept of phishing and social engineering.
2. To study the purpose of GoPhish in authorized security awareness campaigns.
3. To analyze the results of the phishing simulation.
4. To identify weaknesses in employee email-handling practices.
5. To explain the security risks caused by credential theft and malicious attachments.
6. To recommend effective employee training and awareness programs.
7. To identify email security controls that reduce phishing risks.
8. To establish organizational policies for reporting and responding to phishing incidents.
9. To improve the overall security awareness of employees.
10. To develop a continuous improvement plan for phishing prevention.

4. Overview of GoPhish

GoPhish is a tool used by security professionals to conduct authorized phishing simulations. It allows an organization to create simulated phishing campaigns and measure how recipients interact with them.

The tool can help assess whether employees:

- Open simulated phishing emails.
- Click links in those emails.
- Submit information to a simulated landing page.
- Interact with simulated attachments, where supported by the campaign setup.
- Report suspicious messages to the security team.

The results can help the organization determine which employees or departments may benefit from additional training.

GoPhish should be used only with proper organizational authorization, privacy safeguards, and a clearly defined testing scope. A simulation should be designed to educate employees and improve security rather than embarrass or punish them.

5. Analysis of the phishing campaign report

The report from ABC Technologies Pvt. Ltd. provides three important findings.

Campaign finding	Meaning	Security concern
40% clicked the phishing link	A significant portion interacted with the simulated message	Employees may not recognize suspicious links
20% entered login credentials	Some employees submitted credentials to the simulated page	Employees may be vulnerable to credential theft
Several downloaded a malicious attachment	Some recipients interacted with an attachment	Employees may not recognize unsafe files

The exact number of affected employees cannot be calculated without knowing the total number of participants. The report also does not establish whether the same employees clicked a link, submitted credentials, and downloaded an attachment.

These findings should therefore be treated as indicators of security awareness gaps rather than proof that an actual attack succeeded.

5.1 Analysis of the 40% click rate

A click rate of 40% means that a substantial proportion of participating employees clicked the simulated phishing link.

This may indicate that employees trusted the appearance or wording of the email without checking whether the sender and destination were legitimate.

Possible reasons include:

1. The email appeared to come from a familiar organization or colleague.
2. The message used urgent language.
3. Employees were unaware of common phishing indicators.

4. The link appeared similar to a genuine company website.
5. Employees were working quickly and did not inspect the message carefully.
6. Previous phishing awareness training may have been insufficient.
7. Employees may not have known how to report suspicious emails.

A high click rate increases the risk that a real phishing message could lead employees to a fraudulent website or expose them to harmful content.

5.2 Analysis of the 20% credential submission rate

The report states that 20% of employees entered their login credentials into the simulated phishing page.

This is an important security concern because credentials can provide access to email accounts, internal applications, cloud platforms, and business information.

Possible reasons include:

1. Employees may not have verified the website address.
2. The email may have appeared to be an official login request.
3. Employees may have been accustomed to signing in through email links.
4. The simulated message may have created urgency or fear.
5. Employees may not have understood the importance of protecting passwords.
6. Employees may not have recognized the signs of a fake login page.

In a real attack, stolen credentials could be used to attempt unauthorized account access. Multifactor authentication and phishing-resistant authentication methods can reduce this risk, although the level of protection depends on the authentication system and attack method.

5.3 Analysis of malicious attachment downloads

The report also indicates that several employees downloaded a malicious attachment.

Attachments may be disguised as invoices, reports, job applications, delivery notices, or business documents. A harmful file may attempt to exploit a software vulnerability or persuade the recipient to run unsafe content. Downloading a file does not necessarily mean that malware executed or that a device was compromised. However, the event indicates that the employee may need additional guidance on safe attachment handling.

Possible weaknesses include:

- Trusting unexpected attachments.
- Failing to verify the sender.
- Ignoring unusual file names or extensions.
- Using outdated software.
- Not reporting suspicious messages.
- Lack of awareness about potentially harmful documents and executable files.

The organization should combine employee training with technical controls that detect and block malicious attachments.

6. Security weaknesses demonstrated by employees

The phishing simulation highlights several possible weaknesses in employee behavior and organizational security practices.

6.1 Lack of phishing awareness

Employees may not know how to recognize fake emails, suspicious links, impersonation attempts, or fraudulent login pages.

Recommendation: Conduct regular awareness sessions with examples of phishing emails, warning signs, and safe response procedures.

6.2 Trust in unknown senders

Employees may trust an email because it contains a company logo, a familiar display name, or professional-looking language. However, these features can be copied.

Recommendation: Teach employees to verify the actual sender address and confirm unusual requests through a separate, trusted communication channel.

6.3 Failure to verify links

A link may display text that looks legitimate while directing users to a different website.

Recommendation: Train employees to inspect the destination address, avoid unexpected login links, and access important services through official bookmarks or known websites.

6.4 Weak credential protection practices

Entering credentials into an unverified page can expose an account to unauthorized access.

Recommendation: Use multifactor authentication, password managers, and phishing-resistant authentication where practical. Employees should never disclose passwords in response to unexpected email requests.

6.5 Unsafe attachment handling

Employees may download or open files without checking whether the message was expected or whether the sender is genuine.

Recommendation: Teach employees to verify unexpected attachments and use approved reporting procedures rather than opening questionable files.

6.6 Inadequate incident reporting

If employees do not report suspicious emails, the security team may not know that a phishing campaign is targeting the organization.

Recommendation: Provide a simple reporting mechanism, such as a dedicated email address or an approved phishing-reporting button.

6.7 Excessive trust in urgency

Attackers frequently use statements such as "Your account will be disabled" or "Payment must be completed immediately" to encourage rushed decisions.

Recommendation: Train employees to pause, verify unusual requests, and follow established approval procedures even when a message claims the matter is urgent.

6.8 Insufficient security culture

Employees may consider security the responsibility of the IT department alone.

Recommendation: Establish a security culture in which every employee understands their role in protecting company information.

7. Possible consequences of successful phishing attacks

Phishing can affect an organization in several ways.

7.1 Credential theft

If an employee submits credentials to a fraudulent website, an attacker may attempt to access the employee's account. The consequences depend on the account's permissions and the authentication protections in place.

7.2 Unauthorized access to company systems

A compromised account may allow access to email, internal applications, shared documents, or other business resources.

7.3 Malware infection

A malicious attachment may attempt to install malware if it is opened or executed in a vulnerable or inadequately protected environment. This could affect the user's computer or, in some cases, other connected systems.

7.4 Data leakage

An attacker who gains access to business accounts may attempt to obtain confidential documents, customer information, employee records, or financial data.

7.5 Financial loss

Phishing can be used to deceive employees into making unauthorized payments, changing supplier bank details, or revealing financial information.

7.6 Business disruption

An incident may require accounts to be disabled, devices to be isolated, passwords to be reset, and systems to be investigated. These activities can interrupt normal business operations.

7.7 Reputational damage

If customer or business information is exposed, the organization may lose the trust of customers, employees, partners, and suppliers.

7.8 Legal and compliance consequences

A data breach may require investigation, notification, and other corrective actions depending on applicable laws, contractual requirements, and the type of information involved.

8. Recommended employee awareness programs

Employee awareness training is one of the most important methods of reducing phishing risk. Training should be continuous, practical, and relevant to employees' everyday responsibilities.

8.1 Basic phishing awareness training

The organization should explain what phishing is, how it works, and why attackers target employees.

Training should cover:

- Suspicious sender addresses.
- Unexpected links and attachments.
- Requests for passwords or confidential information.
- Unusual payment or account-change requests.
- Urgent or threatening language.
- Fake login pages and impersonation attempts.

Employees should receive clear examples and practice identifying suspicious messages.

8.2 Regular simulated phishing exercises

ABC Technologies Pvt. Ltd. should conduct periodic authorized simulations to measure improvements in employee behavior.

The campaigns should use varied scenarios and avoid relying on a single predictable template. The objective should be to identify training needs and measure progress over time.

Results should be analyzed at an aggregate level wherever possible. Individual results should be handled confidentially and used primarily for constructive training.

8.3 Role-based training

Different employees face different phishing risks.

For example:

- Finance employees should receive training on payment fraud and supplier bank-detail changes.
- Human resources employees should learn to identify fraudulent resumes and employee-document requests.
- IT administrators should receive training on credential theft, privileged-account protection, and targeted phishing.
- Senior managers should learn about impersonation and business email compromise.
- General employees should receive training on suspicious links, attachments, and reporting procedures.

8.4 Short and frequent training sessions

Long training sessions may be difficult for employees to remember. The organization can provide short learning modules throughout the year.

Topics can include one phishing indicator, one practical example, and one recommended action per session.

8.5 Practical demonstrations

Employees should learn how to inspect sender details, verify website addresses, recognize unexpected login requests, and report suspicious messages.

Demonstrations should use safe examples that do not expose real credentials or encourage employees to visit dangerous websites.

8.6 Security awareness communications

The organization can send regular newsletters, posters, internal announcements, and short reminders about current phishing patterns.

Messages should be clear, easy to understand, and available in languages appropriate for the workforce.

8.7 Positive reinforcement

Employees should be encouraged to report suspicious emails, even if they have already clicked a link.

The organization should avoid a blame-based culture. Punishing employees for reporting mistakes may discourage early reporting and make incidents harder to contain.

8.8 Training evaluation

After training, employees can complete short assessments or participate in another authorized simulation.

The security team should compare results over time to determine whether awareness programs are reducing risky behavior.

9. Email security controls

Employee training should be supported by technical controls. Even well-trained employees can make mistakes, so email systems must provide additional protection.

9.1 Spam filtering

Email security gateways should identify and filter suspicious messages based on sender reputation, message characteristics, known threats, and other available detection signals.

Spam filtering reduces the number of unwanted and potentially harmful messages that reach employee inboxes.

9.2 Sender Policy Framework (SPF)

SPF is an email authentication mechanism that allows a domain owner to specify which mail servers are authorized to send messages using that domain.

Correct SPF configuration can help receiving systems detect certain forms of sender impersonation. However, SPF alone does not prevent every type of phishing attack.

9.3 DomainKeys Identified Mail (DKIM)

DKIM uses a digital signature to help receiving systems verify that an email is associated with a domain and that signed message content has not been altered in ways detectable by the signature.

DKIM helps support email authenticity, but it does not prove that every message from a domain is trustworthy.

9.4 Domain-based Message Authentication, Reporting and Conformance (DMARC)

DMARC builds on SPF and DKIM. It allows domain owners to specify how receiving systems should handle messages that fail authentication alignment and can provide reporting about authentication results.

ABC Technologies should configure SPF, DKIM, and DMARC correctly for its email domains and gradually enforce an appropriate DMARC policy after monitoring legitimate email sources.

9.5 Malicious attachment filtering

Email gateways should inspect attachments for known malware and suspicious characteristics. Risky file types can be blocked or restricted according to business requirements.

Additional controls may include file sandboxing, content disarm and reconstruction, and restrictions on executable attachments.

9.6 URL protection

Email systems can inspect links for known malicious destinations, rewrite links for security checking where appropriate, and block access to known phishing websites.

URL protection should complement, rather than replace, employee awareness training.

9.7 Multifactor authentication

Multifactor authentication requires an additional verification method beyond a password.

It can reduce the impact of stolen passwords. Where feasible, phishing-resistant methods such as passkeys or security keys should be prioritized for sensitive and privileged accounts.

9.8 Endpoint protection

Endpoint detection and response tools and updated anti-malware software can help identify suspicious activity on employee devices.

Organizations should configure endpoints to receive security updates and restrict unnecessary software execution.

9.9 Email encryption and data protection

Sensitive business communications should use approved encryption and data protection mechanisms where required. Data loss prevention controls can help identify and restrict unauthorized transmission of sensitive information.

9.10 Logging and monitoring

Email systems should retain appropriate security logs. Security teams should monitor suspicious sender activity, repeated phishing attempts, reported messages, and unusual account behavior.

10. Organizational policies to reduce phishing attacks

ABC Technologies should create clear policies that explain the responsibilities of employees, managers, and IT personnel.

10.1 Email usage policy

The email policy should describe acceptable use, safe attachment handling, restrictions on sharing confidential information, and procedures for dealing with suspicious messages.

10.2 Password policy

Employees should use unique passwords and approved password-management tools. Passwords should never be shared through email or entered into unverified login pages.

10.3 Multifactor authentication policy

Multifactor authentication should be required for sensitive business applications and privileged accounts, with stronger phishing-resistant methods used wherever practical.

10.4 Incident reporting policy

Employees should know exactly how to report a suspected phishing email or accidental credential disclosure. The reporting process should be quick, accessible, and supported by the IT security team.

10.5 Access control policy

Access to applications, documents, and databases should be granted according to job responsibilities. Unnecessary privileges should be removed.

10.6 Software installation policy

Employees should not install unapproved software or run unexpected attachments. Approved software distribution and endpoint protection should be used to reduce malware risks.

10.7 Remote working policy

Employees working remotely should use approved devices, secure network connections, multifactor authentication, and organization-approved remote access tools.

10.8 Vendor and payment verification policy

Requests to change supplier bank details, transfer money, or disclose sensitive business information should be verified through an independent, trusted communication channel.

10.9 Employee privacy policy

Phishing simulations should have defined objectives, authorized scope, limited data collection, and appropriate retention periods. Credentials should not be collected as real passwords during simulations.

10.10 Policy review

Policies should be reviewed regularly and updated when the organization changes its technology, business processes, or threat environment.

11. Incident response procedure for phishing attacks

If an employee interacts with a real phishing email, ABC Technologies should respond quickly to limit possible damage.

1

Detection

Identify the suspicious email or activity.

2

Reporting

Notify the IT security team immediately.

3

Containment

Block the message and restrict affected accounts or devices when necessary.

4

Investigation

Determine whether credentials were exposed or malware executed.

5

Recovery

Reset credentials, remove threats and restore affected systems.

6

Review

Document findings and improve preventive controls.

Figure 2: Phishing incident response workflow.

Explanation of the steps

1. Detection: Identify suspicious emails through employee reports, email security alerts, or unusual account activity.
2. Reporting: Employees should notify the designated security team without delay.
3. Containment: Security personnel may remove malicious messages, block malicious destinations, revoke suspicious sessions, and isolate affected devices when appropriate.
4. Investigation: Determine which users interacted with the message, whether credentials were submitted, and whether any attachment was executed.
5. Recovery: Reset exposed credentials, remove malware if present, restore affected systems, and verify that unauthorized access has stopped.
6. Review: Record the incident, identify the cause, and improve security controls and employee training.

If an employee accidentally submits credentials, the organization should not wait for proof of misuse before taking reasonable protective action.

12. Measuring the effectiveness of security awareness

The organization should measure whether its training and technical controls are improving security over time. Important performance indicators include:

Indicator	**What it measures**
Phishing click rate	Percentage of recipients who click simulated phishing links
Credential submission rate	Percentage who submit information to simulated phishing pages
Attachment interaction rate	Percentage who interact with simulated risky attachments
Reporting rate	Percentage of recipients who report simulated phishing messages
Time to report	How quickly suspicious emails are reported
Repeat interaction rate	Whether employees repeatedly exhibit risky behavior
Training completion rate	Percentage of employees who complete assigned training

These indicators should be interpreted together. A low click rate is useful, but a high reporting rate and timely reporting are also important signs of an effective security culture.

The organization should compare campaigns using similar measurement methods and take account of differences in campaign design.

13. Implementation plan for ABC Technologies Pvt. Ltd.

The organization can use the following phased approach to address the weaknesses identified in the report.

Phase	Recommended activity	Expected result
Phase 1	Review the GoPhish report and identify training needs	Clear understanding of weaknesses
Phase 2	Conduct employee awareness training	Better recognition of suspicious emails
Phase 3	Improve email filtering and authentication	Fewer phishing messages reaching inboxes
Phase 4	Strengthen MFA and account access controls	Reduced risk from stolen passwords
Phase 5	Establish reporting and incident response procedures	Faster detection and containment
Phase 6	Conduct follow-up simulations	Measurement of improvement
Phase 7	Review results and update policies	Continuous improvement

Management should assign responsibility for each activity, provide the necessary resources, and review progress periodically.

14. Expected outcomes

After implementing these recommendations, ABC Technologies Pvt. Ltd. should aim to achieve the following outcomes:

1. Employees become more capable of identifying suspicious emails.
2. The number of employees clicking simulated phishing links decreases.
3. Credential submission to fraudulent websites decreases.
4. Employees handle unexpected attachments more safely.
5. Suspicious emails are reported more quickly.
6. Email authentication and filtering improve.
7. Unauthorized access caused by stolen credentials becomes less likely.
8. Malware-related risks are reduced through endpoint and email protection.
9. Incident response becomes faster and more organized.
10. The organization develops a stronger security awareness culture.

These outcomes should be verified through follow-up measurements rather than assumed immediately after training.

15. Conclusion

The GoPhish assessment at ABC Technologies Pvt. Ltd. identified important weaknesses in employee responses to simulated phishing messages. The 40% click rate, 20% credential submission rate, and reported attachment downloads indicate that the organization needs to strengthen employee awareness and technical protection.

In conclusion, a combination of employee awareness, technical controls, organizational policies, and continuous evaluation will help ABC Technologies reduce the likelihood and impact of successful social engineering attacks.

Question 3: DNS Zone Transfer Security Assessment Using Dig

1. Introduction

Domain Name System (DNS) is an important component of computer networking. It translates human-readable domain names, such as example.com, into IP addresses that computers use to communicate with each other. DNS also stores information about mail servers, name servers, and other network services.

Organizations depend on DNS to provide websites, email services, internal applications, and network communication. If DNS is incorrectly configured, it may expose sensitive information about the organization's network and create security risks.

The Dig tool, which stands for Domain Information Groper, is a command-line utility used to query DNS servers and examine DNS records. Security professionals use Dig to troubleshoot DNS problems and perform authorized DNS assessments.

One important DNS operation is a DNS Zone Transfer, which allows DNS information to be copied from a primary DNS server to an authorized secondary DNS server. This process helps keep DNS servers synchronized.

A DNS Zone Transfer uses the AXFR query type for a full zone transfer. When a DNS server incorrectly permits unauthorized AXFR requests, an external party may be able to retrieve the zone's DNS records.

In this case, the DNS assessment report generated using Dig shows that the organization's DNS server permits a successful AXFR request. The exposed information includes internal hostnames, mail servers, and DNS records.

This finding indicates a potential DNS configuration weakness. The organization must determine whether the transfer was authorized, identify which records were exposed, and implement appropriate access controls to prevent unauthorized disclosure.

2. Aim

To analyze the DNS assessment report generated using Dig, understand the security implications of an unauthorized DNS Zone Transfer, identify potential attack risks, and recommend suitable measures to secure the organization's DNS infrastructure.

3. Objectives

1. To understand the role of DNS in computer networks.
2. To study the purpose and operation of the Dig tool.
3. To understand DNS zones and DNS Zone Transfer mechanisms.
4. To analyze the security implications of an improperly configured AXFR request.
5. To identify the risks associated with exposed internal hostnames and DNS records.
6. To explain how attackers may misuse exposed DNS information.
7. To recommend suitable DNS server configuration and access controls.
8. To understand the importance of DNS monitoring and auditing.
9. To establish best practices for protecting DNS infrastructure.

10. To improve the confidentiality, integrity, and availability of organizational DNS services.

4. Overview of the Domain Name System

DNS is a distributed naming system that translates domain names into information required for network communication.

For example, when a user enters a website name in a browser, the computer uses DNS to obtain the corresponding IP address or other relevant DNS information.

Without DNS, users would often need to remember numerical IP addresses to access network services.

4.1 Main functions of DNS

1. Name resolution: DNS translates domain names into IP addresses.
2. Email routing: DNS MX records identify the mail servers responsible for receiving email for a domain.
3. Service discovery: Certain DNS records help clients locate particular network services.
4. Name server identification: NS records identify the name servers responsible for a DNS zone.
5. Network administration: DNS records help administrators manage and organize services associated with a domain.
6. Internal network operations: Organizations may use private DNS zones to resolve internal server names and application addresses.

4.2 Importance of DNS security

DNS information can reveal details about an organization's network. If records are unnecessarily exposed, attackers may learn the names of systems, identify email infrastructure, and discover potential entry points for further investigation.

DNS security is therefore important for protecting organizational infrastructure, reducing information disclosure, and maintaining reliable access to network services.

5. Overview of the Dig tool

Dig is a command-line tool used to query DNS servers and retrieve DNS information. It is commonly available on Linux systems and can be installed through DNS utility packages.

Security administrators use Dig to verify DNS records, troubleshoot name resolution, check DNS server responses, and investigate DNS configuration problems.

5.1 Main uses of Dig

1. Retrieve IP addresses associated with a domain.
2. Examine MX records for email services.
3. Identify authoritative name servers.
4. Inspect DNS record types such as A, AAAA, NS, MX, and TXT.
5. Query a specified DNS server.
6. Investigate DNS responses and errors.
7. Test whether an authorized DNS Zone Transfer is configured correctly.

5.2 Example of a normal DNS query

The following command requests the IPv4 address record for a domain:

dig example.com A

Here:

- dig runs the DNS query tool.
- example.com is the domain being queried.
- A specifies the IPv4 address record type.

This query helps determine which IPv4 address the DNS server returns for the domain.

5.3 Example of checking mail server records

dig example.com MX

This command retrieves MX records associated with the domain. These records identify mail servers responsible for receiving email for that domain.

5.4 Example of checking authoritative name servers

dig example.com NS

This command requests the domain's NS records and helps identify its authoritative name servers.

These queries are useful for normal DNS administration and security verification.

6. Understanding DNS zones and Zone Transfer

6.1 What is a DNS zone?

A DNS zone is an administratively managed portion of the DNS namespace. It contains DNS records for the names and services managed within that zone.

For example, a zone may contain records for:

- The main website.
- Mail servers.
- Authoritative name servers.
- Application servers.
- Other hostnames managed by the organization.

An organization may manage separate public and private zones. Public zones generally contain records intended to support services available to external users, whereas private zones may contain internal network information.

6.2 What is a DNS Zone Transfer?

A DNS Zone Transfer is a process used to copy DNS zone information between DNS servers.

It allows a secondary DNS server to obtain records from the primary server and maintain an up-to-date copy of the zone.

AXFR is the DNS query type used for a full zone transfer. Another mechanism, IXFR, can be used to transfer incremental changes in a zone.

Zone transfers are legitimate administrative operations. The security problem occurs when a server permits transfers to unauthorized clients.

6.3 Why Zone Transfers are necessary

Zone transfers support several important functions:

1. Maintaining synchronized copies of DNS information.
2. Supporting redundancy and reliability.
3. Allowing secondary DNS servers to provide name resolution.
4. Improving resilience if one DNS server becomes unavailable.
5. Supporting centralized management of DNS records.

Zone transfers should therefore not be disabled indiscriminately when secondary DNS servers depend on them. Instead, they should be restricted to authorized servers.

7. Analysis of the DNS assessment report

The assessment report indicates that the organization's DNS server accepts an AXFR request and returns DNS zone information.

The report identifies the following exposed information:

- Internal hostnames.
- Mail server information.
- DNS records associated with the zone.

This finding suggests that the DNS server's zone-transfer permissions may be too permissive.

7.1 Exposure of internal hostnames

Internal hostnames may reveal the naming conventions and structure of an organization's network.

For example, names that describe application servers, development systems, administrative services, or database systems may reveal the purpose of different machines.

This information may help an attacker understand the organization's infrastructure.

However, an internal hostname alone does not necessarily mean that the associated system is accessible from the internet. Network routing, firewalls, access controls, and DNS configuration determine whether a system can actually be reached.

7.2 Exposure of mail servers

MX records and related DNS information may identify the organization's email infrastructure.

An attacker could use this information to understand which mail systems support the organization and to plan targeted phishing or email-related reconnaissance.

Mail server exposure does not itself establish that the email service is vulnerable. The security implications depend on the server configuration, authentication controls, and email security measures.

7.3 Exposure of other DNS records

A zone may contain records that identify websites, service endpoints, aliases, name servers, and other systems.

If unnecessary or sensitive records are included in a transferable zone, they may reveal additional information about the organization's technology environment.

7.4 Unauthorized information disclosure

The central security concern is that an unauthorized party may retrieve a collection of DNS records that were not intended for them.

The exposed information may reduce the effort required to map the organization's network and identify systems that deserve further security review.

The organization should investigate whether the exposed records belong to a public zone or an internal zone. The latter may create greater confidentiality concerns.

8. Security risks associated with unauthorized AXFR

8.1 Network reconnaissance

Attackers often collect information about a target before attempting further actions. A successful unauthorized zone transfer can provide a structured list of DNS records, reducing the need to discover hostnames individually.

This may help an attacker identify important systems for additional investigation.

8.2 Identification of critical systems

DNS names may indicate which systems provide important functions, such as authentication, email, application hosting, or database services.

If attackers identify critical systems, they may focus their subsequent security probing on those assets.

8.3 Exposure of internal naming conventions

Internal naming patterns may reveal the organization's departments, environments, applications, or server roles.

This can help an attacker prepare more convincing impersonation attempts or target systems that appear important.

8.4 Targeted phishing

Knowledge of mail servers, department names, or business application names may help an attacker create more convincing phishing messages.

For example, an attacker might impersonate an IT department or refer to a known application in a fraudulent email.

A zone transfer does not directly cause phishing, but the information obtained may make targeted social engineering easier.

8.5 Discovery of outdated or forgotten systems

Old DNS records may refer to development environments, abandoned services, or systems that are no longer actively maintained.

If these systems still exist and are inadequately protected, they may represent security weaknesses that require investigation.

8.6 Exposure of internal architecture

A large set of DNS records may reveal relationships between services, aliases, mail infrastructure, and other network components.

This can give an attacker a better understanding of the organization's technical environment.

8.7 Increased risk of follow-on attacks

The information obtained through an unauthorized transfer may be combined with other information sources.

This could help an attacker plan additional reconnaissance or search for misconfigured services.

Nevertheless, an unauthorized AXFR response alone does not prove that any server has been compromised.

8.8 Business and compliance impact

If a transfer exposes sensitive internal information, the organization may need to investigate the incident, review relevant policies, and determine whether contractual or regulatory requirements apply.

Potential consequences include increased incident response costs, disruption, and reputational damage.

9. Security weaknesses demonstrated by the report

The assessment suggests several possible weaknesses that should be investigated.

9.1 Incorrect zone-transfer permissions

The DNS server may permit transfers from clients that are not authorized to receive the zone.

This is the main configuration issue indicated by the report.

9.2 Insufficient separation of public and private DNS data

Internal records may have been placed in a zone accessible to external clients, or the server may be using inappropriate transfer permissions.

9.3 Inadequate DNS configuration reviews

If DNS permissions are not periodically reviewed, unsafe settings may remain in place for long periods.

9.4 Excessive information disclosure

The organization may maintain unnecessary DNS records that reveal more information than required for normal operations.

9.5 Lack of DNS monitoring

If zone-transfer attempts are not logged or monitored, the security team may not detect repeated unauthorized requests.

9.6 Weak change-management practices

DNS configuration changes made without proper review or documentation may accidentally permit broader access than intended.

9.7 Incomplete asset inventory

Old hostnames and records may remain in the DNS zone after systems have been decommissioned.

The security team should validate these potential weaknesses before deciding on corrective actions.

10. Recommended best practices for securing DNS infrastructure

10.1 Restrict AXFR to authorized servers

The most important corrective action is to configure the authoritative DNS server so that full zone transfers are allowed only for approved secondary DNS servers.

The administrator should verify the configuration using the server's documentation and confirm that unauthorized clients cannot retrieve the zone.

10.2 Use transaction signatures where appropriate

TSIG, or Transaction Signature, is a mechanism that uses shared secret keys to authenticate certain DNS messages, including supported zone-transfer operations.

When supported and properly configured, TSIG can provide an additional authentication control between DNS servers.

TSIG keys must be securely generated, stored, distributed, rotated, and protected from unauthorized access.

10.3 Separate public and private DNS zones

The organization should ensure that internal records are maintained in appropriately restricted private DNS zones.

Public DNS should contain only the records required for external name resolution. Internal records should be accessible only to authorized clients and services.

10.4 Apply least privilege

DNS servers and their administrative accounts should have only the permissions necessary for their functions.

Zone transfers should be restricted to the smallest practical set of authorized secondary servers.

10.5 Review DNS records regularly

Administrators should identify and remove obsolete, duplicate, unnecessary, or incorrectly configured records.

Record cleanup should be performed carefully to avoid interrupting legitimate services.

10.6 Monitor DNS server logs

DNS logs should be reviewed for unauthorized AXFR requests, unusual query patterns, unexpected configuration changes, and suspicious administrative activity.

Alerts should be generated when transfer requests originate from unrecognized sources.

10.7 Keep DNS software updated

DNS server software should be supported and patched according to vendor recommendations.

Security updates help address known software vulnerabilities and improve the reliability of DNS services.

10.8 Use firewalls and network access controls

Firewall rules should restrict DNS management traffic and zone-transfer connections to the required servers and networks.

Access restrictions should match the organization's DNS architecture and operational requirements.

10.9 Protect DNS administration

Administrative access should use strong authentication, least-privilege permissions, and secure management channels.

Changes to zone-transfer settings and DNS records should be authorized and documented.

10.10 Conduct regular security assessments

Authorized assessments should verify that zone transfers work for legitimate secondary servers while remaining unavailable to unauthorized clients.

Security testing should also review public and private DNS separation, software patch status, access controls, and logging.

11. Safe verification using Dig

The following commands can be used by an authorized administrator to inspect DNS information and verify zone-transfer restrictions.

Step 1: Identify the authoritative name servers

dig example.com NS

This returns NS records for the example domain.

Step 2: Review mail server records

dig example.com MX

This helps identify the mail servers listed in the domain's DNS records.

Step 3: Check a zone transfer with authorization

dig @192.0.2.53 example.com AXFR

This is an illustrative command using a documentation-only IP address. Replace the server and domain with those belonging to an authorized assessment environment.

The command requests a full zone transfer. A correctly secured server should permit the transfer only when the requesting client is authorized according to the server's configuration.

A successful response indicates that the server returned zone data to the requester. It does not automatically prove that the configuration is wrong: the requester may be an authorized secondary server, and the zone may intentionally permit public transfers in a specific environment.

Step 4: Verify the corrected configuration

After making changes, the administrator should repeat the authorized verification and confirm that legitimate secondary servers still synchronize successfully while unauthorized clients are denied.

The expected result is that zone-transfer permissions match the documented DNS architecture.

12. DNS security monitoring and incident response

The organization should implement a process for responding to unauthorized zone-transfer findings.

1. Confirm the finding: Verify that the transfer was successful and determine whether the requesting client was authorized.
2. Identify the exposed data: Establish which DNS records were returned and whether internal or sensitive information was included.
3. Correct permissions: Restrict transfers to approved secondary servers and configure suitable authentication controls.
4. Review logs: Examine DNS logs for other unauthorized transfer attempts and unusual queries.
5. Review affected systems: Determine whether the exposed hostnames point to systems with additional security weaknesses.
6. Protect sensitive information: Remove unnecessary records and correct inappropriate public/private DNS separation.

7. Document the incident: Record the cause, impact, remediation steps, and responsible personnel.
8. Retest the configuration: Verify that unauthorized transfers are rejected and legitimate transfers continue to function.
9. Review related controls: Check firewall rules, access permissions, software updates, and DNS administration practices.
10. Improve procedures: Update DNS configuration standards and schedule periodic reassessments.

If the assessment reveals only a configuration weakness and no evidence of further activity, the organization should still correct the issue and review relevant logs.

13. Recommended DNS security architecture

External Clients

Request public DNS information

Public Authoritative DNS

Publishes necessary public records and restricts AXFR

Authorized Secondary DNS Servers

Zone transfers permitted only for approved servers

Private Internal DNS

Internal records accessible only to approved networks and clients

Logging, Monitoring and Administration

Auditing, access control, configuration management and alerts

Figure 3: Recommended DNS security architecture.

Explanation

- Public DNS contains only the records required for public services.
- Private DNS keeps internal records separate from public DNS.
- Zone transfers are allowed only between authorized DNS servers.
- Authentication mechanisms such as TSIG may be used to protect supported transfer operations.
- Monitoring helps administrators detect suspicious requests and configuration changes.
- Administrative access is controlled and DNS changes are documented.

This design reduces unnecessary information exposure while preserving the availability and synchronization of legitimate DNS services.

14. Expected outcomes

After implementing the recommended measures, the organization should aim to achieve the following outcomes:

1. Unauthorized DNS Zone Transfers are prevented.
2. Internal hostnames and records receive appropriate protection.
3. Public DNS contains only necessary information.
4. DNS server access permissions are clearly defined.
5. Authorized secondary DNS servers continue to receive required zone updates.

6. DNS software is maintained and updated.
7. Suspicious DNS activities are detected more effectively.
8. Obsolete DNS records are identified and removed.
9. DNS configuration changes are documented and reviewed.
10. The overall confidentiality, integrity, and availability of DNS services improve.

15. Conclusion

The DNS assessment report generated using Dig indicates that the organization's DNS server permits a successful AXFR request, exposing internal hostnames, mail server information, and other DNS records. This finding suggests that the server's zone-transfer configuration may allow unauthorized access to DNS information.

DNS Zone Transfers are necessary for synchronizing primary and secondary DNS servers, but they should be restricted to authorized systems. Unrestricted transfers may assist network reconnaissance, reveal internal naming conventions, expose information about important services, and support targeted phishing or further security investigations.

To address these risks, the organization should restrict AXFR permissions, use appropriate authentication mechanisms such as TSIG, separate public and private DNS zones, remove unnecessary records, maintain supported DNS software, and monitor suspicious activity.

Regular security assessments and documented configuration reviews are also necessary to ensure that DNS infrastructure remains properly protected. Following these best practices will reduce unnecessary information disclosure, improve DNS security, and help maintain reliable organizational network services.